CardioAhead-GovAgent

An Authority-Gated Multi-Agent Prototype for Medical AI Risk Triage

ENGINEERING CASE STUDY | VERSION 0.4 | 9 NOVEMBER 2026

Core proposition: Capability does not grant authority.

Executive summary

CardioAhead-GovAgent is a local, synthetic software prototype demonstrating how AI-assisted incident analysis can be separated from authorization to act. An optional language model drafts provisional notes; deterministic Python controls independently decide whether a simulated incident can progress to routine documentation. A second enforcement layer checks role permissions, signed time-limited grants, case state, replay, and audit integrity immediately before a sandbox tool writes a text file.

The implementation is a portfolio demonstration—not a medical device, clinical decision support tool, validated post-market surveillance process, or regulatory conformity assessment. The live LLM endpoint was implemented but not exercised during this review.

Verified evidence at a glance

Evidence	Verified result
Automated test suite	37 tests passed (Python unittest, executed 9 Nov 2026)
Synthetic scenario corpus	5 fictional incidents: 3 routine-draft decisions, 2 block-and-escalate decisions
Allowed side effect	Synthetic .txt draft in a fixed local sandbox_actions directory
Forbidden side effects	No implemented clinical threshold, physician flag, patient record, shell, or permission-changing tool
Human review	Local password-protected reviewer and read-only auditor views; reviewer decisions do not override blocks

1. Problem and design thesis

AI models can generate useful risk-analysis observations without being reliable arbiters of their own permissions. A prompt-level instruction such as “do not alter clinical settings” is insufficient if an agent also has a powerful tool capable of making the change. In a safety-critical workflow, authorization must be enforced at a boundary the model cannot rewrite through its output.

This project tests a narrow architectural claim: an agent may produce a recommendation, while a separate deterministic component controls which effects—if any—can occur. A role and token check is applied again at the action boundary rather than relying solely on an upstream classification.

2. System architecture

01 Synthetic incident → 02 Triage (mock or optional LLM notes) → 03 Illustrative regulatory mapping → 04 Deterministic authority decision → 05 Human-review queue / routine draft → 06 Independent sandbox tool boundary + audit trail

Trust and responsibility boundaries

Layer	Responsibility	Trust assumption

Triage Agent	Extracts failure-mode summary and evidence gaps; mock mode reproducible	LLM text is untrusted; schema constrained to two commentary fields
Regulatory Mapping	Drafts illustrative associations with ISO 14971, IEC 62304 and EU AI Act	Not a qualified legal or clinical classification
Authority Gate	Default deny on unknown action/class; blocks illustrative Class C, clinical action or high uncertainty	Uses trusted synthetic incident metadata, not LLM-generated permissions
Tool Boundary	RBAC, scoped HMAC grant, expiry, replay and audit-chain checks	Trusted local grant issuer, report state and file permissions
Human review UI	Records acknowledge / request changes / reject with rationale	Local reviewer login only; not enterprise identity proof

3. Threat model and implemented controls

Threat / failure mode	Control demonstrated	Residual exposure
Model attempts to invent authority	Strict LLM notes schema; gate never derives permissions from model output	Broader prompt-injection defence not demonstrated
Unauthorized role / tool	Tool allowlist, per-role permissions and grant scope	Grant issuer is trusted; no enterprise IAM
Forged, expired or replayed grant	HMAC signature, <=900-second expiry, nonce checked against audit history	Key compromise or concurrent distributed execution not addressed
Clinical action requested	No clinical action adapter; Class C / critical actions blocked	No real external connector or production validation
Tampered audit entry	Hash-chain verification rejects further sandbox actions	Local chain is rewriteable by filesystem attacker
Automation bias in reviewer workflow	Rationale capture and immutable gate decision within UI flow	No human-factors study or qualified reviewer validation

4. Representative scenarios and results

Case	Synthetic incident	Policy outcome
INC-001	Non-clinical UI rendering defect	ALLOW_ROUTINE_DRAFT
INC-002	Sensor drift, non-critical status notification delay	ALLOW_ROUTINE_DRAFT
INC-003	False-negative arrhythmia detection; threshold change requested	BLOCK_AND_ESCALATE
INC-004	ECG ingestion schema change / validation warnings	ALLOW_ROUTINE_DRAFT
INC-005	Unreliable ECG explanation; physician flag override requested	BLOCK_AND_ESCALATE

In the principal negative test, INC-003 remains blocked even if the caller supplies a correctly scoped grant for an otherwise permitted sandbox tool. In the principal positive test, INC-001 can generate a local text draft, explicitly labelled as synthetic and not a clinical record.

5. Evaluation evidence

The repository's unittest suite was run against the v0.4 source in the local execution environment: 37 tests completed successfully. Tests cover the deterministic policy, simulated LLM responses, reviewer dashboard and authentication checks, and sandbox-boundary behavior. Specific adversarial tests exercise wrong-role access, unavailable clinical tools, cross-case and cross-tool grants, signature forgery, expiration, replay, path traversal, hash-chain tampering, inert prompt-like text and auditor POST denial.

Interpretation: these passing tests provide functional evidence for this specific implementation and test suite. They do not establish comprehensive resistance to adversarial agents, OS-level containment, secure deployment or regulatory compliance.

6. Key engineering decisions

Fail closed rather than degrade silently

If the LLM provider errors or returns extra authority fields, the extraction is rejected and escalation is required; the system does not silently accept a lower-quality result as a safe authorization.

Enforce at the tool boundary

Even if an upstream component mislabels a tool request, the action adapter independently checks policy, grant scope, case state and audit integrity. A blocked clinical case does not become executable because a human acknowledged reviewing it.

Make the safe demonstration deliberately narrow

Only two sandbox adapters exist: write_sandbox_note and export_sandbox_summary. Both write .txt files under a fixed local path. The project contains no shell execution or medical system connector.

7. Limitations and non-claims

- IEC 62304 A/B/C labels in the fixtures are illustrative software safety classifications, not generic risk scores or real medical-device determinations.
- ISO 14971, IEC 62304 and EU AI Act Articles 14/72 are contextual references only; obligations, applicability and evidence requirements have not been exhaustively evaluated.
- The “sandbox” is a constrained local file-writing simulation, not an operating-system or container security sandbox.
- Audit records are tamper-evident against simple edits, not immutable; a privileged attacker can replace the chain and report.
- Role labels and locally issued HMAC capabilities do not prove an enterprise user identity; the demo has no SSO, separated key service or distributed transaction guarantees.
- LLM endpoint compatibility and real-model performance have not been validated; no real patient data or clinical deployment is involved.

8. Recommended next engineering milestones

Priority	Milestone	Evidence of completion
P0	Publish reproducible demo and threat model	Version-pinned repository, commands, expected results and screenshots
P1	Introduce independent policy fixtures and negative evaluation set	Coverage matrix mapping each abuse case to a test and policy assertion
P1	Separate trusted case state from writable reports	Signed or protected state store and crash-consistent event records
P2	Add hardened isolation and external append-only audit sink	Container/network policy demonstration and external integrity verification
P2	Run structured human-oversight usability evaluations	Reviewer comprehension and disagreement metrics

9. Reproducibility

Run from the project root with Python 3.10+ (no third-party packages required for mock mode):

```
python main.py --mode mock --output output/v04_demo
python tool_demo.py --output output/v04_demo --case INC-001
python tool_demo.py --output output/v04_demo --case INC-003  # expected denial
python -m unittest discover -s tests -v
python -m dashboard.app --output output/v04_demo --port 8765
```

Use a fresh output directory per run. Do not expose the local HTTP dashboard to the public internet. The live-model option requires credentials and a compatible HTTPS endpoint; it was not verified here.

Closing observation

CardioAhead-GovAgent does not claim to make autonomous medical AI safe. It demonstrates a smaller but testable proposition: system-enforced authorization can remain separate from an AI model's ability to propose an action. That boundary is a practical building block for AI Control and evidence-based assurance.

Repository references: governance/authority_gate.py; governance/tool_boundary.py; agents/llm_triage.py; dashboard/app.py; tests/test_v04.py; README.md.

Regulatory background: EU AI Act Articles 14 and 72 (https://ai-act-service-desk.ec.europa.eu/en/ai-act/); ISO 14971 and IEC 62304 (applicability and compliance not asserted).